

SWitCH Cyber - Pós-Graduação em Segurança de Informação, Cibersegurança e Privacidade

**Auditoria da Segurança de Informação (ASINF)
Professor Hermano Correia**

Relatório de Auditoria Interna
para a "Ferroviária Tech"

Group 3:

Sara Bastos, 1250420

Marta Ferreira, 1201845

José Rodrigues, 1940368

RELATÓRIO DE AUDITORIA INTERNA

ISO/IEC 27001:2022

Ferroviária Tech, S.A.

Sistemas de Informação aplicados ao setor ferroviário

Organização auditada	Ferroviária Tech, S.A.
Representante da organização	Dr. João Maria - Diretor de Tecnologia e Inovação
Equipa auditora	Auditores Associados, Lda. Ana Costa (Auditora Coordenadora)
Data da auditoria	1 de junho de 2026 a 7 de agosto de 2026 (10 semanas)
Tipo de auditoria	Parcialmente remota - presencial + <i>Microsoft Teams</i> + <i>Azure</i> remoto
Normas de referência	ISO/IEC 27001:2022 ISO/IEC 27002:2022 ISO 19011 RGPD NIS2 IEC 62443
Data do relatório	7 de agosto de 2026
Versão	1.0 - Final
Classificação	CONFIDENCIAL

Auditora Coordenadora: Ana Costa | CISA, CRISC | ana.costa@auditores-associados.pt

1. Declaração de independência do auditor

Em conformidade com a norma ISO 19011:2018, cláusula 5.2 (Princípios de auditoria - Independência), a equipa auditora da Auditores Associados, Lda. declara formalmente que:

- Não tem qualquer relação hierárquica, funcional ou financeira com a Ferroviária Tech, S.A. ou com as áreas auditadas.
- Não participou na conceção, implementação ou manutenção do SGSI da organização.
- Não tem interesses comerciais ou pessoais que possam comprometer a objetividade das conclusões desta auditoria.
- Os resultados desta auditoria refletem exclusivamente as evidências objetivas recolhidas e analisadas durante o processo de auditoria.

Auditora coordenadora	Ana Costa - CISA, CRISC Auditores Associados, Lda.
Declaração	A equipa auditora confirma a ausência de conflito de interesses com a Ferroviária Tech, S.A.
Data	7 de agosto de 2026
Assinatura	

2. Introdução

2.1. Objetivo da auditoria

A presente auditoria interna tem como objetivo avaliar o nível de implementação e a eficácia do Sistema de Gestão de Segurança da Informação (SGSI) da Ferroviária Tech, S.A., em conformidade com os requisitos da norma ISO/IEC 27001:2022 e os controlos do Anexo A (ISO/IEC 27002:2022), bem como a conformidade com o RGPD, a Diretiva NIS2 e os *standards* IEC 62443 aplicáveis ao contexto ferroviário.

No âmbito desta avaliação, foi analisada a implementação e eficácia dos controlos de segurança da informação e avaliou-se a conformidade com o RGPD e os requisitos de proteção de dados pessoais.

Foi também objeto de análise o processo de gestão de risco de segurança da informação, incluindo ativos OT/SCADA utilizados nas operações ferroviárias.

No domínio da resiliência organizacional, foram revistos os planos de continuidade de negócio (BCP/DRP) e os resultados dos testes realizados para validar a eficácia perante cenários de interrupção dos serviços críticos.

A auditoria incluiu também a avaliação da segurança da infraestrutura de rede, sistemas e ambientes *cloud Azure* e os mecanismos de proteção implementados para garantir a operação segura da mesma.

Foram analisados os processos de gestão de identidades e acessos (IAM/PAM) e a implementação de MFA, com o objetivo de verificar a adequação dos controlos de acesso aos sistemas e à informação.

No contexto dos sistemas industriais, foi avaliada a eficácia dos controlos de segurança aplicados aos sistemas OT/SCADA ferroviários e examinada a gestão de fornecedores e a segurança da cadeia de fornecimento.

Por fim, a auditoria avaliou a adequação dos programas de formação e consciencialização em segurança da informação, verificando o seu alcance, periodicidade e eficácia na promoção de uma cultura de segurança alinhada com os objetivos da organização.

2.2. Âmbito da auditoria

A presente auditoria teve como foco os sistemas de informação e os processos considerados mais relevantes para a atividade da Ferroviária Tech, S.A. no setor ferroviário. Foram considerados o Sistema de Gestão de Tráfego Ferroviário (SGTF), a Plataforma de Bilhética Eletrónica e o Sistema de Monitorização de Infraestrutura (SMI / OT/SCADA). A avaliação incluiu ainda o ERP corporativo, o portal de colaboração interna e o sistema de gestão documental.

Para além disso, a análise abrangeu também a infraestrutura tecnológica que suporta estes sistemas, como a rede corporativa, os *data centers* em Lisboa, Porto e Aveiro e o ambiente *cloud Microsoft Azure*.

No que respeita os processos organizacionais, foi auditada a gestão de acessos, a gestão de incidentes, a continuidade de negócio, a gestão de fornecedores, a conformidade RGPD, a segurança dos sistemas OT/SCADA. Foram ainda avaliadas as ações de formação e sensibilização promovidas junto dos colaboradores.

2.3. Critérios da auditoria

A auditoria foi realizada com base nos requisitos e boas práticas definidos pela ISO/IEC 27001:2022, relativos ao Sistema de Gestão de Segurança da Informação e também pela ISO/IEC 27002:2022 referente aos controlos de segurança da informação previstos no Anexo A. Foram considerados ainda os princípios da ISO/IEC 27005:2022 para a gestão de risco de segurança da informação.

No domínio da proteção de dados e Cibersegurança, foram utilizados como referência o Regulamento Geral sobre a Proteção de Dados (RGPD - Regulamento UE 2016/679) e a Diretiva NIS2 (UE 2022/2555) relativa à segurança de redes e sistemas de informação.

Para a avaliação dos ambientes industriais e operacionais, foram aplicados os referenciais da IEC 62443, dedicados à segurança de sistemas de automação e controlo industrial (OT/SCADA). No âmbito da gestão de tecnologias da informação, foram considerados os princípios e práticas do COBIT 2019.

A condução da auditoria seguiu também as orientações estabelecidas pela ISO 19011:2018 e foram analisadas as políticas, procedimentos e controlos internos implementados pela Ferroviária Tech, S.A. de forma a avaliar o respetivo nível de conformidade e eficácia.

2.4. Equipa de auditoria

Ana Costa	Auditora Coordenadora (CISA, CRISC) 10 semanas
Miguel Ferreira	Auditor Sénior - Segurança SI (CISSP, CEH) 6 semanas
Sofia Lopes	Auditora - Proteção de Dados (CIPP/E, DPO) 5 semanas

Rui Santos	Auditor Técnico - Infraestrutura (CCNA, Security+) 4 semanas
Catarina Neves	Auditora - Continuidade e Risco (ISO 22301) 4 semanas
Contacto	ana.costa@auditores-associados.pt +351 210 000 100

2.5. Datas, locais e agenda

A auditoria decorreu entre 1 de junho e 7 de agosto de 2026, em regime parcialmente remoto, com sessões presenciais nas instalações da Ferroviária Tech, S.A. e sessões remotas via *Microsoft Teams* e acesso supervisionado a consolas de administração. O horário de trabalho foi das 09:00 às 18:00, com pausa de almoço das 13:00 às 14:00. A auditoria não foi gravada. O idioma utilizado foi o português.

Data	Local Auditado	Local Auditor	Método	Hora	Assuntos / Processos Auditados	Auditor
01/06/2026	Sede - Lisboa	Sede - Lisboa	Presencial	09:00-10:00	Reunião de abertura: apresentação da equipa auditora, confirmação de âmbito e agenda	Ana Costa
01/06/2026	Sede - Lisboa	Sede - Lisboa	Presencial	10:00-12:00	Entrevista: Diretor de TI / CISO - políticas de SI, governança e gestão de risco	Ana Costa
01/06/2026	Sede - Lisboa	Sede - Lisboa	Presencial	14:00-16:00	Revisão documental: políticas de segurança, SGSI, registo de ativos e classificação de dados	Miguel Ferreira
01/06/2026	Sede - Lisboa	Sede - Lisboa	Presencial	16:00-18:00	Entrevista: DPO - conformidade RGPD, registo de tratamentos, DPIA	Sofia Lopes
02/06/2026	Sede - Lisboa	Sede - Lisboa	Presencial	09:00-10:30	Inspeção técnica: controlo de acessos físicos, CCTV, <i>clear desk/screen</i>	Rui Santos
02/06/2026	Sede - Lisboa	Sede - Lisboa	Presencial	10:30-13:00	Revisão: gestão IAM/PAM - <i>Active Directory</i> , contas privilegiadas, MFA, revisão periódica de acessos	Miguel Ferreira
02/06/2026	Sede - Lisboa	Sede - Lisboa	Presencial	14:00-16:00	Revisão: gestão de vulnerabilidades, <i>patch management</i> , resultados de <i>pentests</i>	Rui Santos
02/06/2026	Sede - Lisboa	Sede - Lisboa	Presencial	16:00-18:00	Entrevista: Gestor de Continuidade - BCP/DRP, RTO/RPO, resultados de testes	Catarina Neves
08-12/06/2026	Porto - COF	Porto - COF	Presencial	09:00-13:00	Auditoria OT/SCADA: SGTF, SMI - segregação IT/OT, <i>firmware</i> , protocolos industriais, acessos remotos	Miguel Ferreira
08-12/06/2026	Porto - COF	Porto - COF	Presencial	14:00-18:00	Inspeção: segurança física do Centro de Operações Ferroviárias e sala de controlo	Rui Santos
15-26/06/2026	Sede - Lisboa	Sede - Lisboa	Presencial	09:00-13:00	Auditoria RGPD: base legal, direitos dos titulares, transferências internacionais, contratos Art. 28	Sofia Lopes
15-26/06/2026	Remoto (Azure)	Teletrabalho	Remoto - MS Teams + screen share	14:00-18:00	Revisão configurações <i>cloud Azure</i> : IAM, <i>logging</i> , encriptação, NSG, <i>backup</i>	Rui Santos
29/06-10/07/2026	Aveiro - DC DR	Aveiro	Presencial	09:00-13:00	<i>Data Center</i> DR: infraestrutura de <i>backup</i> , replicação, testes BCP/DRP, continuidade de negócio	Catarina Neves
29/06-10/07/2026	Sede - Lisboa	Sede - Lisboa	Presencial	14:00-18:00	Revisão: gestão de fornecedores - contratos, <i>due diligence</i> , monitorização, acessos remotos de terceiros	Ana Costa
13-24/07/2026	-	Teletrabalho	Remoto - assíncrono	09:00-18:00	Análise e consolidação de evidências; análise GAP ISO 27001 e RGPD; classificação de constatações	Equipa completa
27/07-07/08/2026	-	Teletrabalho	Remoto - MS Teams	09:00-18:00	Elaboração do relatório preliminar; <i>management response</i> ; incorporação de comentários	Ana Costa
07/08/2026	Sede - Lisboa	Sede - Lisboa	Presencial	10:00-12:00	Reunião de encerramento: apresentação de constatações, conclusões e próximos passos	Ana Costa
07/08/2026	Sede - Lisboa	Sede - Lisboa	Presencial	12:00	Entrega do Relatório Final	Ana Costa

3. Sumário Executivo

O Sistema de Gestão de Segurança da Informação (SGSI) da Ferroviária Tech, S.A. foi auditado entre 1 de junho e 7 de agosto de 2026, por amostragem, em conformidade com a metodologia da ISO 19011:2018. A auditoria abrangeu os requisitos da norma ISO/IEC 27001:2022 e os controlos do Anexo A, bem como os requisitos do RGPD, NIS2 e IEC 62443, nos locais de Lisboa (Sede), Porto (Centro de Operações Ferroviárias) e Aveiro (Data Center DR), com revisão remota das configurações *Microsoft Azure*.

A auditoria permitiu concluir que o SGSI da Ferroviária Tech, S.A. se encontra parcialmente implementado, com processos, políticas e controlos definidos em múltiplas áreas.

No entanto, foram identificadas 7 não conformidades nas quais 4 são consideradas Maiores (NCM) e 3 Menores (NCm), em particular nas áreas de gestão de risco, controlo de acessos, continuidade de negócio e gestão de incidentes, que comprometem a eficácia do sistema e impedem, no estado atual, a obtenção de certificação ISO/IEC 27001:2022 sem medidas corretivas imediatas.

	NCM	NCm	OBS	OM
Requisitos da norma	3	2	0	0
Controlos Anexo A	1	1	0	0
Total	4	3	0	0

A organização demonstrou colaboração e disponibilidade durante todo o processo de auditoria. Todas as entrevistas foram realizadas conforme planeado e as evidências solicitadas foram, na sua maioria, facultadas.

3.1. Áreas de preocupação

Foram identificadas várias áreas de preocupação que requerem atenção prioritária. No âmbito da gestão de risco, verificou-se que a avaliação de riscos atualmente em vigor não contempla os ativos críticos OT/SCADA (SGTF, SMI), que representam o core operacional da Ferroviária Tech. Esta é a não conformidade de maior impacto potencial, dado o contexto de infraestrutura crítica ferroviária.

Relativamente ao controlo de acessos, foram identificadas contas com privilégios excessivos e ausência de revisão periódica documentada, aumentando significativamente a superfície de ataque interno.

No âmbito da continuidade de negócio, constatou-se que o PCN não foi testado de forma abrangente e não contempla cenários específicos de falha nos sistemas ferroviários, criando um risco operacional elevado.

Quanto à gestão de incidentes, observou-se a inexistência de registo formal e de análise de causa raiz dos incidentes ocorridos. Esta lacuna limita a capacidade de aprendizagem e aumenta a probabilidade de recorrência.

Foi igualmente verificado que a Política de Segurança e Formação se encontra desatualizada e 35% de colaboradores sem formação obrigatória válida, comprometendo a eficácia das medidas de sensibilização e consciencialização implementadas pela organização.

Por último, verificou-se que diversas não conformidades identificadas em 2025 se encontram por resolver sem evidências de ações corretivas.

3.2. Recomendações principais

A equipa auditora recomenda que a Ferroviária Tech, S.A. atribua máxima ao tratamento das 4 não conformidades maiores com prioridade máxima, iniciando de imediato o processo de remediação, nomeadamente a atualização da avaliação de riscos (45 dias) e a revisão de acessos (15 dias).

Recomenda-se também a formalização e implementação de um processo robusto de gestão de incidentes com notificação obrigatória e *Root Cause Analysis* para todos os incidentes registados.

No âmbito da continuidade de negócio, deverá ser efetuada uma revisão ao PCN incorporando cenários de falha nos sistemas OT/SCADA ferroviários, incluindo a realização de um *Tabletop exercise* abrangente.

A Política de Segurança da Informação deverá ser revista, atualizada e formalmente comunicada a todos os colaboradores, com registo de confirmação de leitura.

Para reforçar o acompanhamento das ações corretivas, recomenda-se a implementação de uma ferramenta de *tracking* formal, garantindo o encerramento das NCs da auditoria de 2025.

Por fim, a organização deverá assegurar a conclusão da formação obrigatória em segurança da informação para os 35% de colaboradores em falta, no prazo de 45 dias.

A certificação na norma ISO/IEC 27001:2022 fica estritamente condicionada à resolução das 4 Não Conformidades Maiores identificadas neste documento. O fecho bem-sucedido destas lacunas demonstrará o verdadeiro compromisso da Ferroviária Tech com a segurança nacional e resiliência das infraestruturas críticas de transporte.

Data: 7 de agosto de 2026

Ana Costa | Auditora Coordenadora
CISA, CRISC - Auditores Associados, Lda.

4. Metodologia

4.1. Técnicas de auditoria utilizadas

A auditoria foi realizada através de diferentes técnicas de recolha e validação da informação. Começou-se pela análise de documentos relevantes, incluindo políticas, procedimentos, registos, contratos, relatórios de auditoria e incidentes anteriores. Os responsáveis de várias áreas foram também entrevistados, nomeadamente o CISO, o DPO, o Responsável pela Continuidade de Negócio, o gestor OT/SCADA, o responsável de RH e o gestor de contratos e colaboradores operacionais, para entender os processos e validar a sua aplicação prática.

Para além disso, foi realizada uma inspeção presencial no Porto aos controlos de acesso físico, CCTV, *clear desk/screen* e sala de controlo OT/SCADA, a auditoria incluiu ainda a revisão técnica, com acesso *read-only* supervisionado, das consolas *Active Directory* e *Microsoft Azure*, para verificar a gestão de acessos, segurança da rede, registos de atividades e mecanismos de encriptação.

Por último, foram verificadas as evidências de registos de formação, incidentes, o portal de *compliance* e relatórios de auditorias anteriores.

4.2. Processos e procedimentos auditados

A auditoria incidiu nos processos e controlos considerados mais relevantes para a segurança da informação e para a proteção de dados da organização. Para o efeito, foi analisada a Política de Segurança da Informação, juntamente com a restante documentação associada ao Sistema de Gestão da Segurança da Informação (SGSI). Foram ainda revistos os procedimentos de avaliação e tratamento de riscos, bem como o registo de ativos existente.

No que diz respeito ao controlo de acessos, a análise incidiu sobre os mecanismos *IAM/PAM*, o *Active Directory* e a autenticação multifator. Relativamente aos sistemas *OT/SCADA*, foram observados aspetos relacionados com a separação entre os ambientes *IT* e *OT*, a gestão de *firmware* e os protocolos industriais utilizados.

A conformidade com o RGPD foi avaliada através da consulta dos registos de tratamento de dados, das avaliações de impacto sobre a proteção de dados e dos contratos celebrados com subcontratantes ao abrigo do artigo 28.º. Foram igualmente considerados os procedimentos adotados para a gestão de incidentes, os planos de continuidade de negócio e de recuperação de desastre, a gestão de fornecedores e dos acessos remotos, assim como as ações de formação e sensibilização disponibilizadas aos colaboradores.

Por fim, analisou-se o acompanhamento das auditorias realizadas anteriormente, verificando-se o estado das não conformidades identificadas e a implementação das medidas corretivas definidas para a sua resolução.

4.3. Amostragem utilizada

A auditoria foi realizada por amostragem, em conformidade com a metodologia da ISO 19011:2018. A seleção das amostras foi baseada na criticidade dos processos para o contexto ferroviário, no histórico de incidentes e não conformidades anteriores e na cobertura dos requisitos de maior impacto operacional.

No âmbito da gestão de acessos, foi analisada uma amostra de 30% das contas ativas no *Active Directory*, com foco nos perfis privilegiados. Quanto à proteção dos dados e documentos de RGPD, foi feita uma revisão integral do registo de tratamentos e DPIAs disponíveis.

No caso dos incidentes, foram analisados todos os registados nos últimos 12 meses, através dos *tickets* de *Helpdesk* e dos registos formais existentes, para os fornecedores, foram revistos os contratos dos cinco mais críticos de TI e por último, foi feita uma consulta integral ao sistema LMS para verificar as ações de formação de todos os colaboradores.

4.4. Ferramentas e técnicas utilizadas

Durante a auditoria foram utilizadas várias ferramentas e técnicas de recolha e análise de informação. As entrevistas remotas e as reuniões de abertura e encerramento, foram feitas pelo *Microsoft Teams*. Os controlos técnicos relacionados com *IAM*, *NSG* e *Log Analytics*, foram avaliados com acesso *read-only* supervisionado, às consolas do *Microsoft Azure* e *Active Directory*.

A documentação necessária foi consultada e validada de forma assíncrona através de uma plataforma segura partilhada pela organização e foram também analisados os registos de eventos do *SIEM* e *logs* de autenticação, de maneira a verificar a eficácia dos mecanismos de monitorização e controlo implementados.

5. Constações da auditoria

#	Classif.	Constatação e Evidência Objetiva	Critério ISO 27001:2022	Controlo Anexo A	Impacto	Recomendação / Ação
1	NCM	CONSTATAÇÃO: A avaliação de riscos da Ferroviária Tech omite os ativos críticos operacionais (sistemas OT/SCADA: SGTf e SMI). O plano de tratamento de risco não possui prazos nem cronograma definidos. EVIDÊNCIA: Matriz de Riscos corporativa não inclui sistemas de sinalização ferroviária. Plano de Tratamento de Risco sem datas de implementação das medidas de controlo.	8.2 - Avaliação de riscos de segurança da informação 8.3 - Tratamento de riscos de segurança da informação	5.9 Inventory of information and other associated assets	ALTO - Risco de interrupção operacional ferroviária sem controlos adequados implementados.	Atualizar avaliação incluindo todos os ativos críticos OT/SCADA. Definir cronograma rigoroso no plano de tratamento. Prazo: 45 dias. Resp.: Gestor de Risco.
2	NCM	CONSTATAÇÃO: Não existem registos de revisão recente dos acessos aos sistemas críticos. Foram detetados colaboradores com permissões excessivas em sistemas que não integram o âmbito das suas funções. EVIDÊNCIA: Análise da matriz de acessos no <i>Active Directory</i>: contas ativas com privilégios administrativos sem justificação de negócio. Última revisão de acessos sem data registada.	5.15 - Controlo de acessos 5.18 - Direitos de acesso	5.15 Access control 5.18 Access rights	ALTO - Risco elevado de acesso não autorizado a sistemas críticos ferroviários e dados sensíveis.	Revogar imediatamente acessos excessivos. Implementar processo formal de revisão trimestral com evidências documentadas. Prazo: 15 dias. Resp.: Administrador de Sistemas.
3	NCM	CONSTATAÇÃO: O Plano de Continuidade de Negócio (PCN) foi testado apenas uma vez nos últimos dois anos e o teste não abrangeu cenários de falha nos sistemas OT/SCADA ferroviários. EVIDÊNCIA: Relatório de teste de 2024 foca exclusivamente falha de servidores web. Ausência de simulação de falhas no SGTf ou SMI. Sem registo de Tabletop exercises envolvendo operações ferroviárias.	5.30 - Prontidão das TIC para a continuidade do negócio	5.29 Information security during disruption 5.30 ICT readiness for business continuity	ALTO - Em caso de incidente real nos sistemas OT, a organização não está preparada para responder e recuperar eficazmente.	Atualizar PCN com cenários de falha na operação ferroviária. Executar teste de simulação Tabletop completo cobrindo todos os sistemas críticos. Prazo: 60 dias. Resp.: Gestor de Continuidade.

4	NCM	CONSTATAÇÃO: Incidentes de segurança recentes não foram registrados formalmente no Registro Central de Incidentes. Não existe evidência de análise de causa raiz para incidentes recorrentes. EVIDÊNCIA: Tickets de Helpdesk documentam infecções locais (malware) que não foram reportados no sistema formal de gestão de incidentes. Ausência de relatórios de Root Cause Analysis (RCA) para incidentes repetidos.	5.24 - Planejamento e preparação da gestão de incidentes de SI	5.24 Incident management planning 5.25 Assessment of information security events 5.27 Learning from incidents	ALTO - A ausência de registro formal e análise de causa raiz impede a melhoria contínua e aumenta a probabilidade de recorrência de incidentes.	Tornar obrigatória a notificação formal de todos os incidentes. Implementar modelo de análise '5 Whys' nos tickets. Definir SLA de notificação. Prazo: 30 dias. Resp.: CSIRT.
5	NCm	CONSTATAÇÃO: A Política de Segurança da Informação não é revista há 3 anos (última revisão: 2023). Colaboradores da equipa operacional (SGTF) demonstraram desconhecimento do documento durante entrevistas. EVIDÊNCIA: Documento 'Política de SI' datado de 2023. Entrevistas com colaboradores do SGTF confirmaram que o documento não é conhecido nem foi comunicado recentemente.	5.2 - Política de Segurança da Informação 5.36 - Conformidade com políticas e normas	5.1 Policies for information security	MÉDIO - A política desatualizada e desconhecida não cumpre o papel de diretriz efetiva para a proteção da informação.	Rever e aprovar nova versão da Política de SI. Comunicar formalmente a todos os colaboradores com registro de confirmação. Prazo: 30 dias. Resp.: Responsável SGSI.
6	NCm	CONSTATAÇÃO: Não conformidades identificadas na auditoria interna de 2025 permanecem por resolver. Não existem registros claros das ações corretivas tomadas. EVIDÊNCIA: Relatório de Auditoria Interna 2025 identifica NCs abertas. Portal de compliance sem evidências de mitigação ou encerramento das ações.	9.2.2 - Programa de auditoria interna 10.2 - Não conformidades e ações corretivas	5.36 Compliance with policies, rules and standards	MÉDIO - A acumulação de não conformidades por fechar compromete a maturidade e credibilidade do SGSI.	Investigar e documentar o estado atual de todas as NCs pendentes. Implementar ferramenta formal de tracking de ações corretivas com responsáveis e prazos. Prazo: 30 dias. Resp.: Responsável SGSI.
7	NCm	CONSTATAÇÃO: 35% dos colaboradores não completaram a formação obrigatória em segurança da	7.2 - Competência 7.3 - Conscientização	6.3 Information security awareness,	MÉDIO - Colaboradores sem formação adequada aumentam o	Promover sessões urgentes de formação obrigatória em SI para os

	informação. Os registos de formação na plataforma de RH (LMS) estão incompletos e desatualizados. EVIDÊNCIA: Plataforma LMS de RH regista 35% dos utilizadores sem certificado válido ou registo de presença na formação anual obrigatória de segurança da informação.		education and training	risco de incidentes por erro humano, nomeadamente phishing e engenharia social.	colaboradores em falta. Atualizar e auditar registos no LMS. Prazo: 45 dias. Resp.: Diretor de Recursos Humanos.
--	--	--	------------------------	---	--

6. Resumo das constatações

6.1. Requisitos da norma ISO/IEC 27001:2022

Cláusula	Requisito ISO/IEC 27001:2022	Audit.	NCM	NCm	OBS	Resultado
4.1	Understanding the organization and its context	S	-	-	-	Conforme
4.2	Needs and expectations of interested parties	S	-	-	-	Conforme
4.3	Scope of the ISMS	S	-	-	-	Conforme
4.4	Information security management system	S	-	-	-	Conforme
5.1	Leadership and commitment	S	-	-	-	Conforme
5.2 / 5.36	Policy / Compliance with policies, rules and standards	S	-	1	-	NC menor
5.3	Organizational roles, responsibilities, authorities	S	-	-	-	Conforme
5.15 / 5.18	Access Control/ Access Rights	S	1	-	-	NC maior
5.24	Incident management planning	S	1	-	-	NC maior
5.30	ICT readiness for business continuity	S	1	-	-	NC maior
6.1	Actions to address risks and opportunities	S	-	-	-	Conforme
6.2	Information security objectives	S	-	-	-	Conforme
6.3	Planning of changes	S	-	-	-	Conforme
7.1	Resources	S	-	-	-	Conforme
7.2 / 7.3	Competence / Awareness	S	-	1	-	NC menor
7.4	Communication	S	-	-	-	Conforme
7.5	Documented Information	S	-	-	-	Conforme
8.1	Operational planning and control	S	-	-	-	Conforme
8.2/8.3	Information security risk assessment/ treatment	S	1	-	-	NC maior
9.1	Monitoring, measurement, analysis and evaluation	S	-	-	-	Conforme
9.2.2 / 10.2	Internal audit / Nonconformity and corrective action	S	-	1	-	NC menor
9.3	Management review	S	-	-	-	Conforme
10.1	Continual improvement	S	-	-	-	Conforme
	Total	23	4	3	0	7 com NC

7. Plano de ações corretivas recomendadas

Com base nas não conformidades identificadas, a equipa auditora recomenda o seguinte plano de mitigação. A Ferroviária Tech, S.A. deve submeter um plano formal de ações corretivas com evidências de implementação no prazo máximo de 90 dias após a entrega deste relatório.

#	Classif.	Descrição da NC	Ação Corretiva	Responsável	Prazo	Estado
1	NCM	Avaliação de riscos omite ativos críticos OT/SCADA; plano sem prazos	Atualizar avaliação de riscos com todos os ativos críticos; definir cronograma de mitigação	Gestor de Risco	45 dias	Aberto
2	NCM	Acessos excessivos e sem revisão periódica documentada	Auditar e revogar acessos desnecessários; implementar revisão trimestral formal	Adm. Sistemas	15 dias	Aberto
3	NCM	PCN testado 1x em 2 anos; sem cenários de falha OT	Expandir PCN com cenários OT/ferroviários; executar <i>Tabletop exercise</i> global	Gestor Continuidade	60 dias	Aberto
4	NCM	Incidentes não registados; sem <i>Root Cause Analysis</i>	Tornar notificação formal obrigatória; implementar processo RCA ('5 Whys')	CSIRT	30 dias	Aberto
5	NCm	Política de SI desatualizada (3 anos); desconhecida pela equipa operacional	Rever e aprovar nova versão; comunicar formalmente com registo de confirmação	Responsável SGSI	30 dias	Aberto
6	NCm	NCs de auditorias anteriores por resolver; sem <i>tracking</i> formal	Fechar NCs pendentes; implementar ferramenta de <i>tracking</i> com responsáveis e prazos	Responsável SGSI	30 dias	Aberto
7	NCm	35% colaboradores sem formação obrigatória; registos LMS incompletos	Agendar formações urgentes; auditar e atualizar registos no portal RH	Diretor de RH	45 dias	Aberto

Data máxima para submissão do plano de resposta: 7 de novembro de 2026.

Próxima auditoria de acompanhamento recomendada: 1.º trimestre de 2027.

8. Lista de participantes e entrevistados

Nome	Função / Departamento	Papel	Data	Hora	Duração
Dr. João Maria	Diretor de Tecnologia e Inovação	Rep. da organização	01/06	09:00	-
Ana Costa	Auditora Coordenadora (CISA, CRISC)	Auditora coordenadora	01/06-07/08	09:00	10 sem.
Miguel Ferreira	Auditor Sênior SI (CISSP, CEH)	Auditor sênior	01/06-10/07	Várias	6 sem.
Sofia Lopes	Auditora Proteção de Dados (CIPP/E)	Auditora RGPD	15/06-26/06	09:00	5 sem.
Rui Santos	Auditor Técnico Infraestrutura (CCNA)	Auditor técnico	02/06-26/06	Várias	4 sem.
Catarina Neves	Auditora Continuidade e Risco (ISO 22301)	Auditora BCP/DRP	29/06-10/07	09:00	4 sem.
CISO - Ferroviária Tech	Responsável de Segurança da Informação	Auditado - Entrevista	01/06	10:00	2h
DPO - Ferroviária Tech	Data Protection Officer	Auditado - Entrevista RGPD	01/06 e 15-26/06	Várias	~15h
Responsável OT/SCADA	Centro de Operações - Porto	Auditado - Inspeção OT	08-12/06	09:00	~30h
Gestor de Continuidade	Ferroviária Tech	Auditado - Entrevista BCP	02/06	16:00	2h
Gestor de Contratos	Ferroviária Tech - Procurement	Auditado - Fornecedores	29/06-10/07	14:00	~15h
Resp. de Recursos Humanos	Ferroviária Tech - RH	Auditado - Formação/LMS	02/06	14:00	1h

9. Distribuição do relatório

9.1. Declaração de confidencialidade

Este relatório tem classificação CONFIDENCIAL. O seu conteúdo é de uso exclusivo dos destinatários listados. A sua reprodução ou distribuição a terceiros não autorizados é expressamente proibida sem autorização da Ferroviária Tech, S.A. e da Auditora Coordenadora.

Destinatário	Função	Data de envio	Observações
Dr. João Maria	Diretor de Tecnologia e Inovação	07/08/2026	Entrega em reunião de encerramento
Perfeito Isabel	Diretor-Geral / CEO Ferroviária Tech	07/08/2026	Cópia para arquivo de gestão
Fábio Azeitona	CISO / Responsável de SI	07/08/2026	Análise técnica e plano de mitigação de riscos
Preciosa Pereira	Data Protection Officer	07/08/2026	Conformidade com o RGPD e revisão de privacidade
Ana Costa	Auditora Coordenadora	07/08/2026	Arquivo da equipa auditora

10. Evidências da auditoria

Informação documentada e evidências técnicas analisadas durante a auditoria. As referências a não conformidades (NC1-NC7) indicam a relação com as constatações da secção 4.

Tipo	Designação do documento / evidência	Versão / Data	Observação
Política	Política de Segurança da Informação	2023 (3 anos)	NC5 - Documento desatualizado; última versão sem comunicação aos colaboradores
SGSI	Manual SGSI e Declaração de Aplicabilidade (SoA)	v2.0 - 2025	Âmbito definido; SoA atualizado
Registo	Matriz de Riscos corporativa	Mar. 2026	NC1 - Não inclui sistemas SGTF/SMI nem outros ativos OT/SCADA
Registo	Plano de Tratamento de Risco	Mar. 2026	NC1 - Sem cronograma de implementação das medidas de controlo
Técnica	Matriz de acessos - <i>Active Directory</i>	Jun. 2026	NC2 - Contas com privilégios excessivos sem justificação; última revisão sem data
Técnica	Relatório de teste BCP/DRP	2024	NC3 - Teste limitado a servidores web; sem cenários OT/ferroviários
Incidentes	Tickets de Helpdesk - infeções malware	2025–2026	NC4 - Incidentes locais não reportados no Registo Central de Incidentes
Incidentes	Registo Central de Incidentes	2025–2026	NC4 - Ausência de registo formal de vários incidentes; sem relatórios RCA
Auditoria	Relatório de Auditoria Interna 2025	2025	NC6 - NCs abertas sem evidência de resolução no portal de compliance
Formação	Plataforma LMS de Recursos Humanos	Jun. 2026	NC7 - 35% de colaboradores sem certificado válido de formação obrigatória em SI
RGPD	Registo de atividades de tratamento	2026	Conforme - Completo e atualizado
RGPD	DPIAs realizadas	2024–2026	Conforme - Realizadas para tratamentos de alto risco
Técnica	Configurações <i>Azure</i> - IAM, NSG, logging	Jun. 2026	Conforme - Verificado in loco (acesso <i>read-only</i> supervisionado)
BCP/DRP	Plano de Continuidade de Negócio (PCN) e DRP	v4.0 - 2025	NC3 - PCN não testado com cenários de falha OT

11. Glossário

Termo	Definição
BCP / DRP	Business Continuity Plan / Disaster Recovery Plan - planos de continuidade de negócio e recuperação de desastres.
CISO	Chief Information Security Officer - responsável máximo pela segurança da informação.
CSIRT	Computer Security Incident Response Team - equipa de resposta a incidentes de segurança.
DPO / EDP	Data Protection Officer / Encarregado de Proteção de Dados - responsável pelo cumprimento do RGPD.
DPIA	Data Protection Impact Assessment - avaliação de impacto sobre a proteção de dados.
IAM / PAM	Identity and Access Management / Privileged Access Management - gestão de identidades e acessos privilegiados.
LMS	Learning Management System - plataforma de gestão de formação e registos de aprendizagem.
MFA	Multi-Factor Authentication - autenticação multifator.
NCM	Não Conformidade Maior - incumprimento total de um requisito ou controlo. Impede a certificação se não resolvida.
NCm	Não Conformidade Menor - incumprimento parcial. Requer ação corretiva, mas não impede a certificação se existir plano de resolução aprovado.
NIS2	Diretiva europeia sobre segurança de redes e sistemas de informação (UE 2022/2555), aplicável a setores críticos como o ferroviário.
OBS	Observação - melhoria que aumenta a eficácia do SGSI ou previne uma não conformidade futura.
OM	Oportunidade de melhoria - sugestão que a organização pode avaliar implementar.
OT / SCADA	Operational Technology / Supervisory Control and Data Acquisition - sistemas de automação e controlo industrial (ex: SGTF, SMI da Ferroviária Tech).
RCA	Root Cause Analysis - análise de causa raiz de um incidente ou problema.
RGPD	Regulamento Geral sobre a Proteção de Dados (UE 2016/679).
RPO / RTO	Recovery Point Objective / Recovery Time Objective - objetivos de ponto e tempo de recuperação.
SGSI	Sistema de Gestão da Segurança da Informação.
SGTF	Sistema de Gestão de Tráfego Ferroviário - sistema OT crítico da Ferroviária Tech.
SMI	Sistema de Monitorização de Infraestrutura - sistema OT/SCADA de monitorização da infraestrutura ferroviária.
SoA	Statement of Applicability / Declaração de Aplicabilidade - documento ISO 27001 que lista controlos aplicáveis e exclusões.
Tabletop Exercise	Simulação de gestão de crise em formato de exercício de mesa, sem ativação real dos sistemas.